GitHub AI Radar — 2026-10-10

本期触发：跨工具历史感知授权与严格类型化证据契约。 Strands Box 于 10 月 7 日发布首个开发预览版，将 OS 级隔离、Dogwood 默认拒绝策略、跨工具事件历史和凭据代理组合到 Agent 进程之外；REA 10 月 9 日连续发布 v6.2 与 v6.3，要求工具输出具备可复核的身份、来源与完整性。这是对既有 Sandbox / Runtime Enforcement / Evidence-first 主线的实质深化，而非单纯搬运 Trending。

1. Strands Box：跨 Shell、Python、MCP 和 HTTP 的历史感知策略

- 官方 GitHub： https://github.com/strands-agents/box
- 发布： v0.1.0，2026-10-07 17:24 UTC。仓库创建于 2026-10-02。
- 本次官方 GitHub REST 快照： 291 Stars / 11 Forks，Apache-2.0。项目仍处于早期，不能以此声称大规模普及。
- 核心结构： 操作系统 Sandbox grants 限制 Agent 直接可访问的文件、程序与网络；独立于 Agent 进程的 Box 可信组件通过 Dogwood Local Engine 检查受控 Shell、Python、出站网关和 MCP broker 的操作。Dogwood 规则默认拒绝，显式 permit 才能放行，forbid 可覆盖 permit。
- 关键路线变化： Shell/Python 文件操作、HTTP 请求与 MCP 调用共享事件历史，策略可以参考先前动作、顺序与经过的时间。例如通过受控工具读取文件后，后续出站 HTTP 请求可按历史条件被拒绝。这比每次调用分别检查静态白名单更有表达力。
- 凭据与审计： 网关在被允许的请求中完成凭据注入，Agent 不直接获得底层密钥；策略决策可写入 OTLP JSON 记录。
- 和既有 Radar 去重： 9-26 Docker Sandbox Kit 主要是可移植权限声明/分发；9-29 NVIDIA OpenShell 是 Agent 外部运行时策略执行；10-06 Kubernetes agent-sandbox 是工作负载调度/控制面。Box 的新增轴线是跨工具事件历史驱动的语义/时序授权。
- 限制必须保留： v0.1.x 为开发预览，目前仅支持 Apple Silicon macOS，Linux 尚在计划中。Agent 直接通过自身工具读写文件时，OS grants 生效，但不会自动生成逐次 Dogwood 决策；不能把这一边界误写为全覆盖策略。尚无独立安全测评证明其无法绕过。

官方技术说明（2026-10-07）：https://strandsagents.com/blog/strands-box-the-big-picture/ ；文档：https://strandsagents.com/docs/user-guide/box/

2. REA v6.2 / v6.3：Evidence 从输出文本变成可验证契约

- 官方 GitHub： https://github.com/morluto/rea
- 最新版本： rea-agents-6.2.0，2026-10-09 16:51 UTC；rea-agents-6.3.0，2026-10-09 23:56 UTC。
- 本次官方 GitHub REST 快照： 46,083 Stars / 7,351 Forks，MIT。相较 10-09 Radar 快照（26,123 Stars / 2,940 Forks），约 24.35 小时净增 19,960 Stars / 4,411 Forks。这是两次 API 观测的差值，不是自然日增量；同次官方 Trending 页面显示 14,927 stars today，统计口径与 REST 差值不同。
- 6.2 关键升级： MCP 成功结果改为直接规范化 Evidence；analysis_profile、完整 profile-bound query 记录、工件角色/权限和进程 event_journal 纳入数据契约；Agent 评价 fixtures 要求 Evidence-backed correctness，而非仅看路由或答案措辞。旧版捕获若缺关键身份/事件顺序必须重新采集，不可补造事实。
- 6.3 关键升级： 历史 capture 若缺 producer accounting 或 transaction identity 即拒收；WebMCP 输入改用 input_schema 与 input_schema_sha256；浏览器 shape path 采用类型化属性/数组片段；JavaScript 语义图必须包含 evidence context ID、位置及内联 evidence_contexts 表。
- 技术判断： REA 已从“ 把领域工具交给 Agent ”走向类型化观察 → 规范化证据 → 来源与完整性校验 → 可审计比较。与 10-08 初次收录、10-09 v6.0 路线不同，本次重点是证据协议和兼容性边界。

- 重要限制： 6.2 与 6.3 均含 breaking changes，旧客户端和历史数据不能假设兼容；官方 release notes 可证实契约变化，但尚不能证明独立测评的准确率提高。仅适用于授权的软件分析场景。

3. 本轮未重复上榜的信号

- diagram-design： 官方 REST 为 47,864 Stars，较 10-08 快照的 45,238 Stars 增加 2,626；仍有热度，但未确认足以再次独立入榜的技术路线变化。
- Paperclip / Hindsight： 10-09 已记录持久 Agent 工作区和记忆治理；本轮未核验到新的正式版本足以重复触发。
- Trending 统计提醒： GitHub Trending 的 stars today 不应与两个 REST 采样间的净增量混用，也不能代表软件安全或质量。

综合趋势与科研工作流价值

执行权限边界： OS containment → Agent 外部策略引擎 → 跨工具事件历史 → 语义/时序授权 → 审计记录。

结果证据边界： Tool output → canonical Evidence → typed identity / provenance → completeness checks → reproducible comparison。

这两条路线分别解决 Agent 能否被允许做某事，以及 Agent 有没有可复核的证据支持结论。对科研自动化而言，比单纯增加 MCP 工具更重要的是：工具操作和输出必须能被审计、复现、明确拒绝未知状态。

后续观察

1. Box：跨 Shell/MCP/HTTP 的策略覆盖、时序规则误拒/漏拒、绕过面及未来 Linux 实现一致性。
2. REA：6.2/6.3 迁移成本、证据完整性和旧数据重采样的可重复性。
3. 两者：是否出现公开可复现的安全、性能和端到端准确性 benchmark。

一手资料

- https://github.com/strands-agents/box
- https://github.com/strands-agents/box/releases/tag/v0.1.0
- https://strandsagents.com/blog/strands-box-the-big-picture/
- https://strandsagents.com/docs/user-guide/box/
- https://github.com/morluto/rea/releases/tag/rea-agents-6.2.0
- https://github.com/morluto/rea/releases/tag/rea-agents-6.3.0
- https://github.com/trending?since=daily

数据采样（UTC）： 2026-10-10T00:45:48+00:00。数字来自官方 GitHub REST 与官方 Trending 页面，未进行独立安全/准确性测评。